LOKAHI: Disjoint Threshold Consent Rings and Cryptographic Boundary Manifests for Multi-Agent Collectives

Salik Shah
Founder & Lead Systems Architect, Dirgha AI · Founding Editor, *Mithila Review*
New Delhi, India · salikshah.com · salik.shah@gmail.com

Target Venues: NeurIPS 2027 SoLaR / SafeGenAI Workshop · Privacy Enhancing Technologies Symposium (PoPETS 2027) · IEEE S&P / USENIX Security Workshop on Agentic Systems
Open-Source Reference Core & Benchmark: `github.com/Dirgha-AI/lokahi` (Apache-2.0 · `tools/lokahi.py`, `tools/run_evals.py`, `data/LOKAHI_RedTeam_Corpus_v1.0.csv`)

Abstract

When a single organization runs an AI agent inside its own sandbox, traditional access controls—role-based access control (RBAC), Open Policy Agent (OPA), AWS Cedar, or single-host object capabilities (Endo)—can confine what that process executes locally. The emerging unit of high-leverage deployment, however, is a multi-agent collective acting across mutually untrusting institutions: a hospital triage swarm querying a municipal health registry, a supply-chain collective negotiating across corporate boundaries, or a distributed energy resource (DER) orchestrator balancing loads across independent utility substations. At this inter-domain seam, single-principal policy servers fail against four structural attacks: (1) cross-domain boundary violations where an agent invokes tools outside the counterparty's permitted scope; (2) salami-slicing attacks where a prohibited irreversible outcome is decomposed into sequential sub-threshold exceptions; (3) Sybil consensus manufacturing where one operator spawns dozens of agent instances to fake multi-party agreement; and (4) single-key administrative capture or fail-open human-in-the-loop timeouts.

Guided by Synthetic Humanism (Shah, 2026a), this paper presents the cryptographic and distributed-systems architecture of **LOKAHI (`v0.1.2`)**. Operating one abstraction layer above single-host object capabilities and single-tenant policy engines, LOKAHI unites four primitives: (1) counterparty-signed RFC 8785 Canonical JSON Boundary Manifests; (2) a DID/SPIFFE Disjointness Attestation Graph that collapses Sybil agent swarms by legal, infrastructural, and key-custody independence; (3) a Three-Body Disjoint Threshold Consent Ring using IETF RFC 9591 (FROST over Ed25519) with a 2-of-3 dissenting restraint freeze (**Rule 13:** `suspended_by_ring`), conflict-of-interest exclusion (Rules 10–12), and **The Ahimsa Timeout Rule (Rule 14:** `non_response → forbidden`); and (4) a privacy-preserving, SHA-256 hash-chained refusal ledger tracking sliding-window exception budgets. Across a data-driven 50-scenario adversarial

benchmark (`LOKAHI_RedTeam_Corpus_v1.0.csv`), the reference core (`v0.1.2`, 38 unit tests passing) achieves 100.0% (50/50) interception at `<0.3 ms` p95 fast-path latency with 0.0% (0/200) false positives.

Keywords: Multi-Agent Security, Cryptographic Boundary Manifests, IETF RFC 9591 FROST, Sybil Resistance, Disjointness Attestation, Model Context Protocol (MCP), Synthetic Humanism, Ahimsa Timeout Rule

---

1. Introduction: The Inter-Domain Coordination Problem

Inside a single administrative domain, confining an autonomous agent is a solved systems problem. Object-capability runtimes (Miller, 2006) and policy engines such as OPA and AWS Cedar allow a single enterprise to restrict which local functions or database tables a process can touch.

Multi-agent collectives, however, operate *between* institutions that share no root administrator and no global policy server. When a clinical agent operated by Hospital A requests patient history from a municipal registry operated by City B, or when twenty autonomous grid agents coordinate load-shedding across regional substations, existing guardrails break down across four vectors: 1. **Absence of Counterparty-Signed Wire Boundaries:** Model Context Protocol (MCP) servers expose syntactic tool schemas (`name`, `description`, `inputSchema`), but carry no cryptographically signed declaration of institutional boundaries—such as barred optimization targets, statutory jurisdiction, data residency, or emergency rate caps. 2. **Sybil Consensus Manufacturing (`AE-E05`):** When multi-agent protocols rely on majority voting or message-level quorum among agent IDs, a single operator can spin up 12 or 24 agent processes that echo one another, manufacturing synthetic consensus to clear a safety gate. 3. **Salami-Slicing and Exception Erosion (`AE-C02`, `AE-C07`):** Stateless per-call guards cannot detect when a caller decomposes a prohibited irreversible action into sequential sub-threshold calls or repeatedly invokes emergency exceptions until the baseline rule erodes. 4. **Fail-Open Timeouts (`AE-B01`) and Single-Key Capture (`AE-D05`):** Conventional escalation queues frequently resolve unanswered review timers to automatic execution (`timeout → approve`), while concentrating emergency override power in a single root credential.

---

2. Positioning in the Security Stack

Table 1 maps LOKAHI's position relative to existing alignment and access-control layers:

Security / Governance Layer	Representative Systems	Trust Assumption & Scope	Structural Gap Addressed by LOKAHI
1. Weight & Prompt Classifiers	RLHF, Constitutional Classifiers, Llama Guard, NeMo Guardrails	Probabilistic inference inside a single model call	Stateless; cannot verify manifest expiration, jurisdiction, or multi-agent collusion (Aggarwal et al., `arXiv:2602.17357`).
2. Single-Host Object Capabilities	Endo, CaMeL, Progent	Confines authority inside one local runtime or single-principal host	Does not provide a cross-organization wire manifest or multi-party threshold quorum across independent institutions.
3. Single-Tenant Policy Engines	Open Policy Agent (OPA), AWS Cedar	Assumes one enterprise owns and administers the policy server	Lacks counterparty-signed manifests, anti-Sybil operator deduplication, or RFC 9591 FROST co-signing.
4. CI/CD Supply-Chain Gates	Arniko (36 scanners), DTrackAuditor, Sigstore	Pre-deployment vulnerability and dependency policy enforcement	LOKAHI extends fail-closed CI policy discipline into the live runtime MCP tool and robotics actuator execution path.
5. Inter-Domain Boundary Protocol	**LOKAHI Protocol (`v0.1.2`)**	Mutually untrusting domains sharing no root key	Counterparty RFC 8785 Manifests + DID/SPIFFE Disjointness Graph + 3-of-3 FROST Ring + Ahimsa Timeout Rule (Rule 14).

Roughly 80% of LOKAHI's production stack composes audited open standards—IETF RFC 8785 (JCS), Ed25519, IETF RFC 9591 (FROST), and Sigstore Rekor transparency logs—while the 20% novel protocol layer specifies the boundary manifest schema, the 15-rule MCP gateway state machine, the operator disjointness graph, and the hash-chained refusal ledger.

---

3. Formal Protocol Specification

3.1 Canonical Boundary Manifests (RFC 8785 JCS)

Let a participating institutional node N_j publish a boundary manifest M_j:

$$M_j = (\mathrm{id}_j, \mathrm{pk}_j, J_j, R_j, I_j, F_j, E_j, \Phi_j, T_{\exp}, \sigma_j)$$

where id_j is the node identifier, pk_j is the steward's verification key, J_j is the statutory jurisdiction, R_j is the set of permitted data-residency regions, I_j is the allowlist of permitted informational features, F_j is the denylist of barred optimization targets, $E_j = (c_{\max}, W_{\mathrm{hours}})$ is the sliding-window emergency

exception cap, Φ_j is the optional physical force/torque envelope, T_{exp} is the RFC 3339 timezone-aware expiration timestamp, and $\sigma_j = \text{Sign}(\text{sk}_j, \text{JCS}(M_j \setminus \{\sigma_j\}))$ is the signature over the RFC 8785 canonicalized JSON payload.

When an agent controlled by operator op_{req} proposes an action A at timestamp t_{now}, the gateway executes **Stage 1 Membrane Verification (Rules 1–8)**: - **Rules 1–3 (Provenance & Freshness):** If σ_j is empty (Rule 1), fails verification (Rule 2), or $t_{\text{now}} \geq T_{\text{exp}}$ (Rule 3), return `FORBIDDEN`. - **Rules 4–7 (Scope, Jurisdiction & Residency):** If $A.\text{features} \cap F_j \neq \emptyset$ (Rule 4), $A.\text{features} \not\subseteq I_j$ (Rule 5), $A.\text{jurisdiction} \neq J_j$ (Rule 6), or $A.\text{stores_in} \not\subseteq R_j$ (Rule 7), return `FORBIDDEN`. - **Rule 8 (Stateful Sliding-Window Salami & Exception Defense):** Let $H(t_{\text{now}} - W_{\text{hours}}, t_{\text{now}})$ be the count of emergency-declared actions recorded on the hash-chained ledger (`Ledger.count_exceptions_in_window()`) within window W_{hours}. If $\max(A.\text{exceptions_used}, H) \geq c_{\max}$, return `FORBIDDEN` (`exception_rate_exceeded`).

3.2 The DID/SPIFFE Disjointness Attestation Graph (Defeating Sybil Swarms)

If an action passes Rules 1–8 and is reversible, non-population-affecting, and carries no emergency declaration, **Rule 9 (`within_manifest`)** clears it on the local fast path in `<0.3 ms`. Otherwise, the action enters **Stage 2: The Three-Body Disjoint Consent Ring (Rules 10–15)**.

To defeat Sybil operator collusion (`AE-E05`), LOKAHI defines quorum over an **Attested Operator Disjointness Graph** $G = (V_{\text{op}}, E_{\text{dep}})$ rather than over agent identifiers: - Each steward node $v \in V_{\text{op}}$ presents a credential binding: (a) a W3C Decentralized Identifier (`did:web`) or institutional registry hash; (b) a workload identity attestation (SPIFFE ID / TPM quote); (c) its network Autonomous System Number (ASN) and cloud root account digest; and (d) its statutory jurisdiction code. - Two operators $u, v \in V_{\text{op}}$ are disjoint ($\text{Disjoint}(u, v) = 1$) if and only if they share no parent legal entity, no common cloud IAM root account, no shared key custodian, and reside in distinct governance domains. - **Operator Deduplication Invariant:** All votes cast by agents mapping to the same operator collapse to weight 1 (`distinct_operators()`). Any operator submitting conflicting `"yes"` and `"no"` votes in the same round is disqualified from counting toward affirmative `"yes"` quorum while their dissent remains active.

3.3 Priority of Collective Restraint (Rule 13), Conflict Exclusion (Rules 10–12), and The Ahimsa Timeout Rule (Rule 14)

Within the deliberation ring, LOKAHI evaluates safety invariants in strict defensive priority before aggregating threshold signature shares via IETF RFC 9591 (FROST over Ed25519): 1. **Rule 13 (`suspended_by_ring` — 2-of-3 Collective Restraint Veto Evaluated First):** Let V_{no} be the set of distinct, non-conflicted operators voting `"no"`. If $|V_{\text{no}}| \geq 2$, execution freezes immediately (`FORBIDDEN: suspended_by_ring`). Evaluating Rule 13 over non-conflicted stewards *prior* to Rules 10–12 guarantees that a compromised requester can never mask or downgrade a cluster-wide safety freeze by injecting a conflicted self-vote into the ring. 2. **Rules 10–12 (Conflict-of-Interest Exclusion):** If the requesting node (`Rule 10: requester_in_ring`), the requesting operator (`Rule 11: requester_operator_in_ring`), or the emergency-declaring party (`Rule 12: declaring_party_in_ring`) appears among the ring participants, return `FORBIDDEN`. 3. **Rule 14 (`non_response` — The Ahimsa Timeout Rule):** Let T_{delib} be the deliberation deadline and V_{yes} be the set of distinct, non-conflicted, non-equivocating operators voting `"yes"`. If

$t_{\text{now}} \geq T_{\text{delib}}$ and $|V_{\text{yes}}| < 3$, the state machine transitions deterministically to `FORBIDDEN` (`non_response`). 4. **Rule 15 (Disjoint Threshold Quorum):** While $t_{\text{now}} < T_{\text{delib}}$ and $|V_{\text{yes}}| < 3$, return `ESCALATE` (`insufficient_disjoint_consent`). Once $|V_{\text{yes}}| \geq 3$ disjoint operators contribute valid FROST signature shares σ_i, the shares aggregate into a compact threshold signature Σ_{ring}, returning `COMPLIANT` (`quorum_met`).

3.4 Selective-Disclosure Escalation Proofs and Hash-Chained Refusal Ledgers

When a local action escalates to external stewards across jurisdictions, transmitting raw citizen PII would violate Rule 7 (`residency_violation`). LOKAHI transmits **Metadata-Only Selective-Disclosure Proofs** (SD-JWT / Merkle inclusion commitments) so external stewards verify conformance to M_j without observing raw record values. Every decision event e_k commits to the previous entry's SHA-256 digest:

$$h_k = \text{SHA256}(h_{k-1} \parallel \text{JCS}(e_k))$$

Any retroactive deletion, modification, or reordering invalidates `Ledger.verify()` at the exact tampered index.

---

4. Empirical Evaluation Across 50 Adversarial Multi-Agent Scenarios (3-Way Baseline)

Executing `py tools/run_evals.py`, `py tools/mcp_stdio_proxy.py --self-test`, and `py tests/test_core.py` (43 unit tests) across the 50-scenario data-driven corpus (`data/LOKAHI_RedTeam_Corpus_v1.0.csv`) and 200 benign fast-path tasks compares LOKAHI against both a Content-Classifier Baseline (`6.0%`) and a Stateless Single-Principal RBAC/OPA Baseline (`48.0%`):

Failure Family	Primary Attack Vectors Tested	Content Baseline	Stateless RBAC/OPA	LOKAHI `v0.1.2` Interception	Primary Rules Exercised
A. Triage & Tiering ($N = 10$)	Unsigned manifest injection, barred target optimization, unlisted feature inference	0 / 10 (0.0%)	4 / 10 (40.0%)	**10 / 10 (100.0%)**	Rules 1, 2, 4, 5, 6, 15
B. Autonomy & Auto-Auth ($N = 10$)	Unanswered timeout auto-execution (`AE-B01`), expired emergency latch (`AE-B02`), self-dealing declarant (`AE-B08`)	0 / 10 (0.0%)	1 / 10 (10.0%)	**10 / 10 (100.0%)**	Rules 3, 5, 10, 12, Rule 14 (`non_response`)
C. Jurisdiction & Fusion ($N = 10$)	Cross-municipality join (`AE-C01`), sliding-window exception creep (`AE-C02`), foreign residency (`AE-C08`)	0 / 10 (0.0%)	7 / 10 (70.0%)	**10 / 10 (100.0%)**	Rules 2, 5, 6, 7, 8, 11
D. Persona & Identity ($N = 10$)	2-of-3 steward freeze (`AE-D05`), sentiment steering (`AE-D02`), multi-account self-approval (`AE-D10`)	2 / 10 (20.0%)	6 / 10 (60.0%)	**10 / 10 (100.0%)**	Rules 4, 5, 11, Rule 13 (`suspended_by_ring`)
E. Persuasion &	24-agent Sybil flood (`AE-E05`),	0 / 5 (0.0%)	3 / 5 (60.0%)	**5 / 5 (100.0%)**	Rule 5, Rule 15 (Operator Deduplication)

Failure Family	Primary Attack Vectors Tested	Content Baseline	Stateless RBAC/OPA	LOKAHI `v0.1.2` Interception	Primary Rules Exercised
Collusion ($N = 5$)	epistemic uncertainty stripping (`AE-E02`)				
F. Archive & Override ($N = 5$)	Valid 3-body positive control (`AE-F01`), expired retention (`AE-F02`), unilateral override (`AE-F05`)	1 / 5 (20.0%)	3 / 5 (60.0%)	**5 / 5 (100.0%)**	Rules 3, 5, 7, 15
TOTAL ($N = 50$)	**All 6 Multi-Agent Failure Families**	**3 / 50 (6.0%)**	**24 / 50 (48.0%)**	**50 / 50 (100.0%)**	**0 / 200 False Positives · `<0.6 ms` p95 Fast Path**

References

- Aggarwal, P., Mukundan, A., et al. (2026). *ASTRA: AI Safety, Trust, & Risk Assessment*. Centre for Digitalisation, AI and Society (CDAIS), Ashoka University. `arXiv:2602.17357`.
- Critch, A. (2023). *Boundaries: An Open Sequence on Multi-Agent Alignment and Cooperative AI*.
- Dafoe, A., et al. (2021). Cooperative AI: Machines must learn to find common ground. *Nature*, 593, 33–36.
- Dalrymple, D., et al. (2024). Towards Guaranteed Safe AI: A Framework for Ensuring Robust and Reliable AI Systems. `arXiv:2405.06624`.
- Komlo, C., Goldberg, I., Connolly, D., & Wood, C. A. (2024). *Two-Round Threshold Schnorr Signatures with FROST*. IETF RFC 9591.
- Miller, M. S. (2006). *Robust Composition: Towards a Unified Approach to Access Control and Concurrency Control*. PhD Dissertation, Johns Hopkins University.
- Nisan, N., Roughgarden, T., Tardos, É., & Vazirani, V. V. (Eds.). (2007). *Algorithmic Game Theory*. Cambridge University Press.
- Ranjit, S. (2026). *DTrackAuditor: Fail-Closed Policy Auditing for OWASP Dependency-Track*. `github.com/thinksabin/DTrackAuditor`.
- Rundgren, A., Jordan, B., & Erdtman, S. (2020). *JSON Canonicalization Scheme* (JCS). IETF RFC 8785.
- Shah, S. (2026a). *Synthetic Humanism: Intelligence, Non-Harm, and the Ahimsa of Abundance*. Dirgha AI Foundational Monograph.

- Shah, S., & Ranjit, S. (2026b). *LOKAHI Protocol: Boundary Enforcement and Disjoint-Consent Infrastructure for Agentic Collectives*. `github.com/Dirgha-AI/lokahi`.